

# 敏感信息泄露

## 代码注释泄露

< 返回

滑稽

WEB

已解决

分数: 10 金币: 1

题目作者: harry

— 血: CyberFI0wer

一血奖励: 1金币

解 决: 33053

提 示: 官方交流群: 830263119

描 述: flag{}

启动场景

请输入flag

提交

打开网页一堆滑稽笑脸



F12 查看源代码拿到注释中的 flag

```
1  <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD
2  <html xmlns="http://www.w3.org/1999/xhtml">
3  <head>
4  <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
5  <meta name="viewport" content="width=device-width,height=device-height,minimum-scale=1.0,maximum-
6  <title>BugkuCTF-WEB1</title>
7
8
9  <style type="text/css">
10 body { margin: 0; padding: 0; position: relative; background-image: url(images/xh.jpg); backgro
11
12
13
14 </style>
15
16 </head>
17 <body id="body" onLoad="init()" >
18 <!--flag{48729a7d66f966db}>
19 <script type="text/javascript" src="js/ThreeCanvas.js"></script>
20 <script type="text/javascript" src="js/Snow.js"></script>
21
22 <script type="text/javascript">
23     var SCREEN_WIDTH = window.innerWidth;//
24     var SCREEN_HEIGHT = window.innerHeight;
25     var container;
26     var particle;//粒子
27
```

.DS\_Store 文件泄露

.DS\_Store

X

所需金币: 50

题目状态: 未解出

解题奖励: 金币:50 经验:5

.DS\_Store 是 Mac OS 保存文件夹的自定义属性的隐藏文件。通过.DS\_Store可以知道这个目录里面所有文件的清单。

<http://challenge-925075ffed70f5ad.sandbox.ctfhub.com:10800>

00:27:37

环境续期

停止并销毁环境

每分钟需要1个金币,请根据个人需求

Flag{.....}

提交Flag

WriteUp

觉得这个WP写的不好有更好的想法? [点我提交](#)

QQ二群: 779878715

.DS\_Store 是 MacOS 保存文件夹的自定义属性的隐藏文件

通过 .DS\_Store 可以知道这个目录里面所有文件的清单

访问下载文件

[http://challenge-925075ffed70f5ad.sandbox.ctfhub.com:10800/.DS\\_Store](http://challenge-925075ffed70f5ad.sandbox.ctfhub.com:10800/.DS_Store)

使用工具解析文件

```
C:\Windows\System32\cmd.e> X + v
Microsoft Windows [版本 10.0.26100.4652]
(c) Microsoft Corporation. 保留所有权利。

D:\CTF\Web Tools\Python-dsstore>python main.py DS_Store
Count: 1
2a943cef1a1dab58f79c950ae3f4a02d.txt

D:\CTF\Web Tools\Python-dsstore>|
```

再通过 curl 访问

```
morant@DESKTOP-JRG4U86: ~$ wsl: 检测到 localhost 代理配置, 但未镜像到 WSL。NAT 模式下的 WSL 不支持 localhost 代理。
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$ curl http://challenge-925075ffed70f5ad.sandbox.ctfhub.com:10800/2a943ce
f1a1dab58f79c950ae3f4a02d.txt
ctfhub{6c87aefed1c6237cc056dee8}
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$
```

## .svn 文件泄露

SVN泄露

所需金币: 50

题目状态: 未解出

解题奖励: 金币:50 经验:5

当开发人员使用 SVN 进行版本控制, 对站点自动部署。如果配置不当,可能会将.svn文件夹直接部署到线上环境。这就引起了 SVN 泄露漏洞。

启动中...

环境续期

停止并销毁环境

每分钟需要1个金币,请根据个人需求

Flag{.....}

提交Flag

WriteUp

觉得这个WP写的不好有更好的想法? [点我提交](#)

题目提交

QQ一群: 1028328666

扫描发现有 .svn/ 目录，确认是 .svn 泄露

使用 dvcs-ripper 工具中的 rip-svn.pl 脚本进行 clone

```
perl rip-svn.pl -u http://challenge-f54504e10cb99eb1.sandbox.ctfhub.com:10800/.svn/

(kali@kali)-[~/dvcs-ripper]
$ perl rip-svn.pl -u http://challenge-f54504e10cb99eb1.sandbox.ctfhub.com:10800/.svn/
[i] Found new SVN client storage format!
REP INFO => 1:file:///opt/svn/ctfhub:e43e7ef8-82fb-4194-9673-81c29de69c33
[i] Trying to revert the tree, if you get error, upgrade your SVN client!
Reverted 'index.html'
```

1 entries

仅在旧版本 SVN（1.6 及以前）有用，新版废弃

- **作用：**旧版 SVN 的目录、文件、状态信息记录（版本号 / 修改 / 是否忽略 / 路径关系等）
- **内容：**伪 XML 格式或纯文本
- **历史遗留，**现代 1.7+ 使用 `wc.db` 替代

```
plaintext复制编辑dir
9
https://svn.example.com/repo
...
```

2 format

作用：标识当前 `.svn` 目录的元数据版本

| 数字  | 意义                            | 对应版本 |
|-----|-------------------------------|------|
| 8   | SQLite ( <code>wc.db</code> ) | 1.7  |
| 12  |                               | 1.8  |
| 29  |                               | 1.9  |
| ... |                               | ...  |

举例内容：

```
12
```

表示该工作副本是 SVN 1.8 版本格式

3 pristine/

核心：文件内容仓库

- 保存了 \*\* 所有干净版本的源文件（未修改的原始版本） \*\*
- 文件名是通过 `SHA1 哈希` 重命名后的，防止冲突、利于查找

```
.svn/pristine/ab/cd/abcdef1234567890.svn-base
```

- **作用：**用于对比工作区是否改动
- **本质：**存储的是 \*\* 未被编辑的原始版本 \*\*，类似 Git 的 `objects/`

1.6 以前旧结构，现代 SVN 不再使用。

- 保存清理缓存的基线内容， `.svn-base` 后缀
- 每个工作区文件对比改动时用
- 与 `pristine/` 相似，但这是 \*\* 旧版设计 \*\*

临时文件目录

- 执行 checkout / update / revert 时产生临时数据
- 类似于 `.git/objects/tmp`
- 意外中断操作后可安全删除

SQLite 数据库，现代 SVN 的核心

- **作用：**记录所有元数据信息
- **类型：**标准 SQLite 数据库
- **包含内容：**
  - 仓库信息（URL / UUID / 根路径）
  - 各文件状态（版本 / 是否修改 / lock 信息）
  - 各目录与版本号映射
  - 目录树层级关系
  - pristine 哈希索引

可以用 `sqlite3 wc.db .tables` 查看表：

| 表           | 含义                 |
|-------------|--------------------|
| NODES       | 各个节点（目录、文件）状态      |
| ACTUAL_NODE | 工作区实际状态（冲突、属性）     |
| REPOSITORY  | 仓库信息               |
| PRISTINE    | 哈希表映射至 pristine 目录 |
| LOCK        | 锁信息                |
| WC_LOCK     | 工作目录锁              |

👉 核心：工作副本的实际状态都在这里！

## 7 wc.db-journal

SQLite 数据库的 事务日志

- 突然断电、进程崩溃，未提交事务保留在这里
- 正常关闭后自动消失，此处为临时遗留无影响
- 如果一直存在可能表示该工作区未正常关闭

```
(kali㉿kali)-[~/dvcs-ripper]
$ cd .svn

(kali㉿kali)-[~/dvcs-ripper/.svn]
$ ls -al
total 148
drwxrwxr-x 5 kali kali 4096 Jul 17 06:23 .
drwxrwxr-x 4 kali kali 4096 Jul 17 06:23 ..
-rw-rw-r-- 1 kali kali 3 Jul 17 06:23 entries
-rw-rw-r-- 1 kali kali 3 Jul 17 06:23 format
drwxrwxr-x 4 kali kali 4096 Jul 17 06:23 pristine
drwxrwxr-x 2 kali kali 4096 Jul 17 06:19 text-base
drwxrwxr-x 2 kali kali 4096 Jul 17 06:23 tmp
-rw-rw-r-- 1 kali kali 122880 Jul 17 06:23 wc.db
-rw-rw-r-- 1 kali kali 0 Jul 17 06:23 wc.db-journal

(kali㉿kali)-[~/dvcs-ripper/.svn]
$
```

找到 flag

```
(kali㉿kali)-[~/dvcs-ripper/.svn]
$ cd pristine

(kali㉿kali)-[~/dvcs-ripper/.svn/pristine]
$ ls -l
total 8
drwxrwxr-x 2 kali kali 4096 Jul 17 06:23 7f
drwxrwxr-x 2 kali kali 4096 Jul 17 06:23 bf

(kali㉿kali)-[~/dvcs-ripper/.svn/pristine]
$ cd 7f

(kali㉿kali)-[~/dvcs-ripper/.svn/pristine/7f]
$ ls -l
total 4
-rw-rw-r-- 1 kali kali 33 Jul 17 06:23 7f037ff68edbc31f803b870149b61591fc1de96f.svn-base

(kali㉿kali)-[~/dvcs-ripper/.svn/pristine/7f]
$ cat 7f037ff68edbc31f803b870149b61591fc1de96f.svn-base
ctfhub{f32f58453a9bce5899d85428}

(kali㉿kali)-[~/dvcs-ripper/.svn/pristine/7f]
$
```

.hg 文件泄露

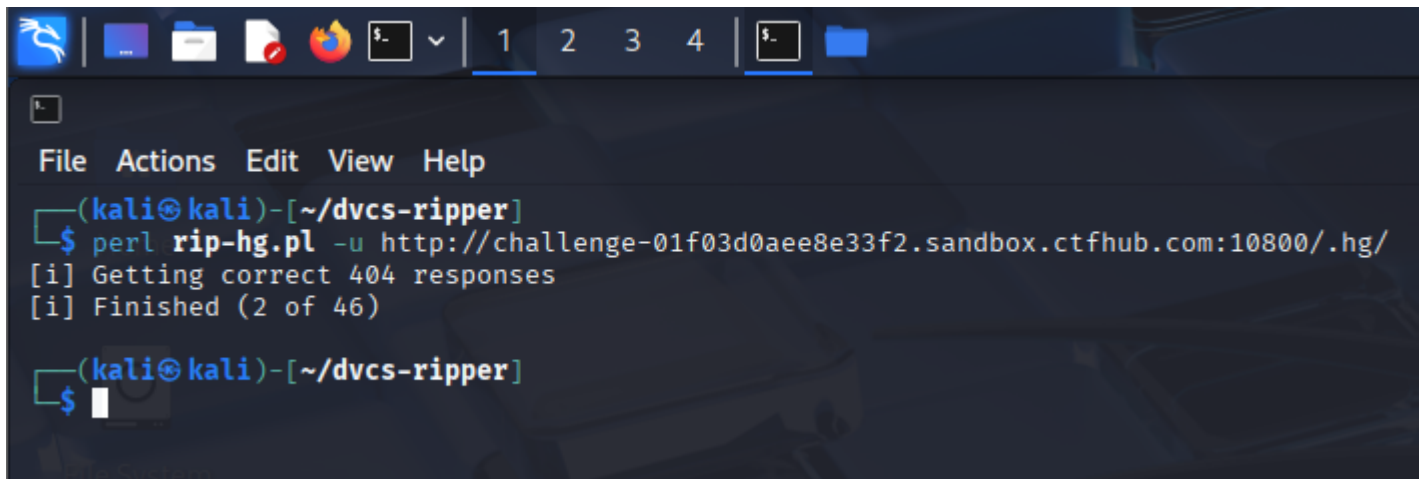




扫描发现有 `.hg/` 目录，确认是 `.hg` 泄露

使用 `dvcs-ripper` 工具中的 `rip-hg.pl` 脚本进行 clone

```
perl rip-hg.pl -u http://challenge-01f03d0aee8e33f2.sandbox.ctfhub.com:10800/.hg/
```



## 1 00changelog.i

- **作用：**存储提交历史（changelog）的索引信息
- **内容：**二进制格式，指向实际存储内容（通常在 `store/data` 内的 `.i` / `.d` 文件）
- **理解：**类似 Git 的 `refs`，用于追踪变更集元信息的位置
- **扩展：**如果被删，仓库历史版本就会断裂不可恢复

## 2 dirstate

- **作用：**跟踪当前工作区（Working Directory）的状态



- **内容**：记录哪些文件被追踪，哪些被修改、添加、删除
  - **理解**：Mercurial 使用它来快速判断 `status`
  - **结构**：二进制，包含：
    - 当前父提交节点 ID
    - 文件状态（正常 / 修改 / 删除 / 添加 / 忽略 / 未追踪）
    - 时间戳缓存信息等
- 

### 3 last-message.txt

- **作用**：记录最近一次提交信息的提交说明
  - **内容**：纯文本，通常是最近一次 `hg commit -m '...'` 的内容
  - **用途**：辅助撤销、恢复操作
- 

### 4 requires

- **作用**：列出该仓库所依赖的 Mercurial 功能模块
- **内容**：文本格式，每行一个模块名。例如：

```
revlogv1
store
fncache
```



- **影响**：Mercurial 启动仓库时读取它，确保兼容性
  - **常见值**：
    - `revlogv1`：使用 revlog 第一版格式
    - `store`：数据在 `.hg/store`
    - `fncache`：文件名缓存机制（避免路径过长）
- 

### 5 undo.branch

- **作用**：记录 `undo` 操作时恢复的分支
  - **内容**：纯文本，分支名
  - **用途**：撤销到该分支
- 

### 6 undo.desc

- **作用**：记录 `undo` 的描述信息
- **内容**：纯文本，比如 "update"、"revert"
- **用途**：提示你撤销了什么操作

## 7 undo.dirstate

- **作用：**撤销时使用的 `dirstate` 快照
- **内容：**二进制，同 `dirstate` 格式
- **用途：**`hg undo` 时恢复工作目录状态

## 8 store/

- **作用：**存储仓库所有版本数据的核心目录
- **内容：**
  - `00manifest.i`: 跟踪清单 (manifest) 的索引
  - `data/`: 存放具体文件变更的 revlog 数据
  - `phaseroots`, `obsstore`: 变更历史的高级特性数据 (可能未启用)
- **结构：**使用 `.i` (索引) 与 `.d` (数据) 二进制文件配对
- **重要性：**这里存储了全部版本数据。如果被破坏，仓库彻底失效

## 9 wcache/

- **作用：**`working directory cache`
- **内容：**缓存某些工作目录的状态，辅助性能
- **影响：**删除它不会丢数据，只是性能下降 (会重新生成)

拿到 flag 名

```
(kali㉿kali)-[~/dvcs-ripper/.hg/store]
$ cat fncache
data/index.html.i
data/50x.html.i
data/flag_1861928929.txt.i

(kali㉿kali)-[~/dvcs-ripper/.hg/store]
$
```

JavaScript 源码泄露

< 返回

计算器

WEB

已解决

分数: 10 金币: 1

题目作者: harry

— 血: CyberFlower

— 血奖励: 1金币

解 决: 32738

提 示:

描 述: 计算正确即可得到flag

启动场景

请输入flag

提交

打开网页是一个输入框

69+3=?

验证

来源:[BugKu-ctf](#)

这里输入被限制了长度

可以通过前端修改 input 框的 text 的 max-length 值

也可以直接查看 JavaScript 源代码拿到 flag

先查看源码

```
<body>

<span id="code" class="nocode">验证码</span> <input type="text" class="input" maxlength="1"/>
<button id="check">验证</button>
<div style="text-align:center;">
<p>来源:<a href="http://ctf.bugku.com/" target="_blank">BugKu-ctf</a></p>
</div>

</body>
<script src="js/jquery-1.12.3.min.js"></script>
<script type="text/javascript" src="js/code.js"></script>
```

看到引入了一个 code.js 文件（jquery 是框架的不用管）点击查看代码拿到 flag

```
$(function() {
    var code = 9999;
    function codes() {

        var ranColor = '#' + ('00000' + (Math.random() * 0x1000000 << 0).toString(16)).slice(-6); //随机生成颜色
        // alert(ranColor)
        var ranColor2 = '#' + ('00000' + (Math.random() * 0x1000000 << 0).toString(16)).slice(-6);
        var num1 = Math.floor(Math.random() * 100);
        var num2 = Math.floor(Math.random() * 100);
        code = num1 + num2;

        $("#code").html(num1 + "+" + num2 + "=?");
        if ($("#code").hasClass("nocode")) {
            $("#code").removeClass("nocode");
            $("#code").addClass("code");
        }
        $("#code").css('background', ranColor);
        $("#code").css('color', ranColor2);
    }
    codes()

    $("#code").on('click', codes)

    $("#check").click(function() {
        if ($("#input").val() == code && code != 9999) {
            alert("flag{CTF-bugku-0032}");
        } else {
            alert("输入有误!");
        }
    })
})
```

## .git 文件泄露

[< 返回](#)

**source**
WEB
已解决

分数: 20    金币: 3

题目作者: vFREE

一血: dotast

一血奖励: 3金币

解 决: 6406

提 示:

描 述: 我哥说渗透我只用linux环境

启动场景

网页啥也没有，先扫他目录

```
C:\Windows\System32\cmd.exe - python dirsearch.py -u http://114.67.175.224:18718/
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11374

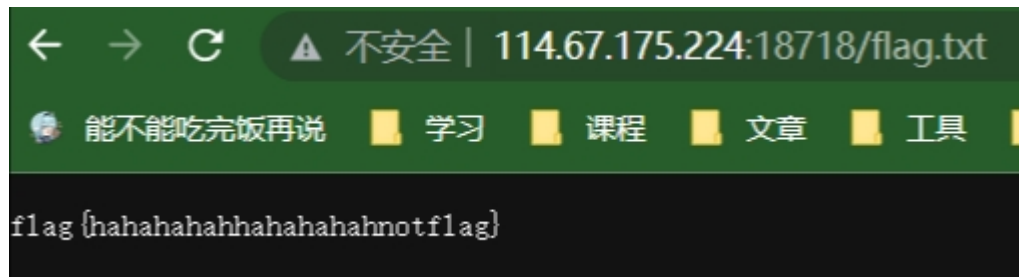
Output File: E:\CTF\_工具\dirsearch\reports\http\_114.67.175.224\_18718\\_22-12-28\_14-19-19.txt

Target: http://114.67.175.224:18718/

[14:19:19] Starting:

```
[14:19:22] 301 - 324B - /.git -> http://114.67.175.224:18718/.git/
[14:19:22] 200 - 133B - /.git/config
[14:19:22] 200 - 14B - /.git/COMMIT_EDITMSG
[14:19:22] 200 - 3KB - /.git/
[14:19:22] 200 - 73B - /.git/description
[14:19:22] 200 - 23B - /.git/HEAD
[14:19:22] 200 - 765B - /.git/branches/
[14:19:22] 200 - 3KB - /.git/hooks/
[14:19:22] 200 - 952B - /.git/info/
[14:19:22] 200 - 240B - /.git/info/exclude
[14:19:22] 200 - 1KB - /.git/logs/
[14:19:22] 200 - 198B - /.git/index
[14:19:22] 301 - 334B - /.git/logs/refs -> http://114.67.175.224:18718/.git/logs/refs/
[14:19:22] 200 - 1KB - /.git/logs/refs/heads/master
[14:19:22] 200 - 1KB - /.git/logs/HEAD
[14:19:22] 301 - 340B - /.git/logs/refs/heads -> http://114.67.175.224:18718/.git/logs/refs/heads/
[14:19:22] 200 - 4KB - /.git/objects/
[14:19:22] 301 - 335B - /.git/refs/heads -> http://114.67.175.224:18718/.git/refs/heads/
[14:19:22] 200 - 1KB - /.git/refs/
[14:19:22] 301 - 334B - /.git/refs/tags -> http://114.67.175.224:18718/.git/refs/tags/
[14:19:22] 200 - 41B - /.git/refs/heads/master
[14:19:23] 403 - 282B - /.ht_wsr.txt
```

有个 flag.txt, 但是是假的



还有个 .git 文件, 下载下来查看

```
(csuk1@csuk1)-[~/114.67.175.224:18718]
$ git reflog
d256328 (HEAD -> master) HEAD@{0}: reset: moving to d25632
13ce8d0 HEAD@{1}: commit: flag is here?
fdce35e HEAD@{2}: reset: moving to fdce35e
e0b8e8e HEAD@{3}: reset: moving to e0b8e
40c6d51 HEAD@{4}: commit: flag is here?
fdce35e HEAD@{5}: commit: flag is here?
d256328 (HEAD -> master) HEAD@{6}: commit: flag is here?
e0b8e8e HEAD@{7}: commit (initial): this is index.html
```

git show 查看历史版本找到 flag

```

(csuk1@csuk1)-[~/114.67.175.224:18718]
$ git show 40c6d51
commit 40c6d51b81775a1590c1b051d9562222e41c4741
Author: vFREE <flag@flag.com>
Date: Sun Jan 17 20:34:43 2021 +0800

    flag is here?

diff --git a/flag.txt b/flag.txt
index aa6f6dc..726e5d1 100644
--- a/flag.txt
+++ b/flag.txt
@@ -1,1 @@
-flag{nonono}
+flag{git_is_good_distributed_version_control_system}

```

.bak 文件泄露

[返回](#)

备份是个好习惯

WEB

已解决

分数: 20

金币: 2

题目作者: harry

— 血: dotast

— 血奖励: 1金币

解 决: 8183

提 示:

描 述: 备份是个好习惯

启动场景

请输入flag

提交

打开网页是个 md5

BugkuCTF - 练习平台

123.206.87.240:8002/web16/

← → ↺

不安全 | 123.206.87.240:8002/web16/

应用

书签工具栏

工作

工作测试

加解密工具

dvwa

题目

常用

d41d8cd98f00b204e9800998ecf8427ed41d8cd98f00b204e9800998ecf8427e

解密啥也不是

# 输入让你无语的MD5

d41d8cd98f00b204e9800998ecf8427ed41d8cd98f00b204e9800998ecf842

解密

md5

[空密码]

扫描后台发现 .bak 备份文件

| 绑定域名查询                   | 批量扫描后台                                                                                                                                                                                                                                                                                                                                                                                                                         | 批量检测注入 | 多种编码转换 | MD5解密相关 | 系统信息                                                                                                    |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|--------|---------|---------------------------------------------------------------------------------------------------------|----|----|--------|---|------------------------------------------------|-----|---|--------------------------------------------|-----|--|--|--|--|--|--|--|--|--|--|--|--|
| 吸取绑定域名列表                 | 开始扫描                                                                                                                                                                                                                                                                                                                                                                                                                           | 停止扫描   | 继续扫描   | 暂停扫描    | <input checked="" type="checkbox"/> 200<br><input type="checkbox"/> 3xx<br><input type="checkbox"/> 403 |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
| 外部导入域名列表                 | 模式 GET - 标准请求                                                                                                                                                                                                                                                                                                                                                                                                                  | 线程 30  | 超时 5   |         | 双击操作 ASP.txt-使用<br>DIR.txt-使用<br>MDB.txt-使用<br>PHP.txt-使用                                               |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
| 作业数里: 1                  | 扫描信息: 扫描完成...                                                                                                                                                                                                                                                                                                                                                                                                                  |        |        |         | 扫描速度: 0/每秒                                                                                              |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
| http://123.206.87.240:80 | <table border="1"><thead><tr><th>ID</th><th>地址</th><th>HTTP响应</th></tr></thead><tbody><tr><td>1</td><td>http://123.206.87.240:8002/web16/index.php.bak</td><td>200</td></tr><tr><td>2</td><td>http://123.206.87.240:8002/web16/index.php</td><td>200</td></tr><tr><td></td><td></td><td></td></tr><tr><td></td><td></td><td></td></tr><tr><td></td><td></td><td></td></tr><tr><td></td><td></td><td></td></tr></tbody></table> |        |        |         |                                                                                                         | ID | 地址 | HTTP响应 | 1 | http://123.206.87.240:8002/web16/index.php.bak | 200 | 2 | http://123.206.87.240:8002/web16/index.php | 200 |  |  |  |  |  |  |  |  |  |  |  |  |
| ID                       | 地址                                                                                                                                                                                                                                                                                                                                                                                                                             | HTTP响应 |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
| 1                        | http://123.206.87.240:8002/web16/index.php.bak                                                                                                                                                                                                                                                                                                                                                                                 | 200    |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
| 2                        | http://123.206.87.240:8002/web16/index.php                                                                                                                                                                                                                                                                                                                                                                                     | 200    |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                |        |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                |        |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                |        |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |
|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                |        |        |         |                                                                                                         |    |    |        |   |                                                |     |   |                                            |     |  |  |  |  |  |  |  |  |  |  |  |  |

下载下来得到网页源码

robots.txt 文件泄露



[< 返回](#)

需要管理员

WEB

已解决

分数: 35

金币: 3

题目作者: [harry](#)

一血: [dotast](#)

一血奖励: 2金币

解 决: 3248

提 示:

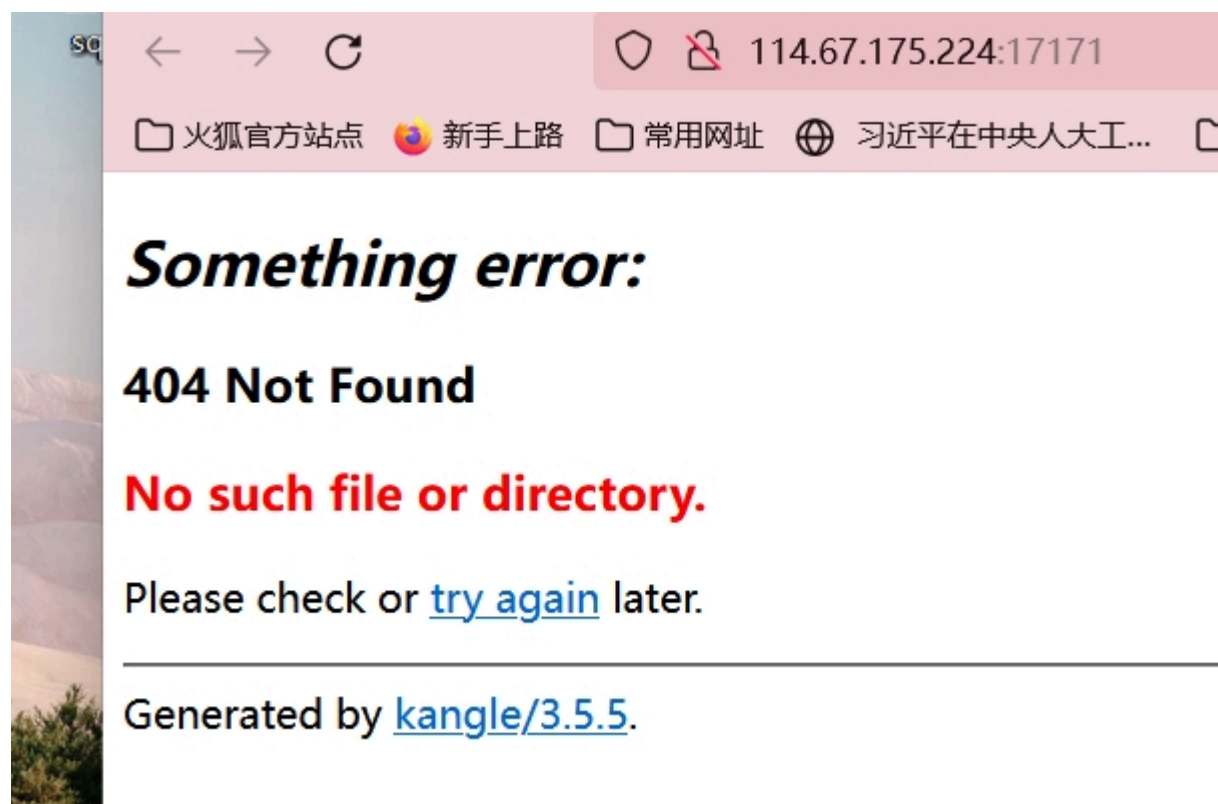
描 述: 好像需要管理员

启动场景

请输入flag

提交

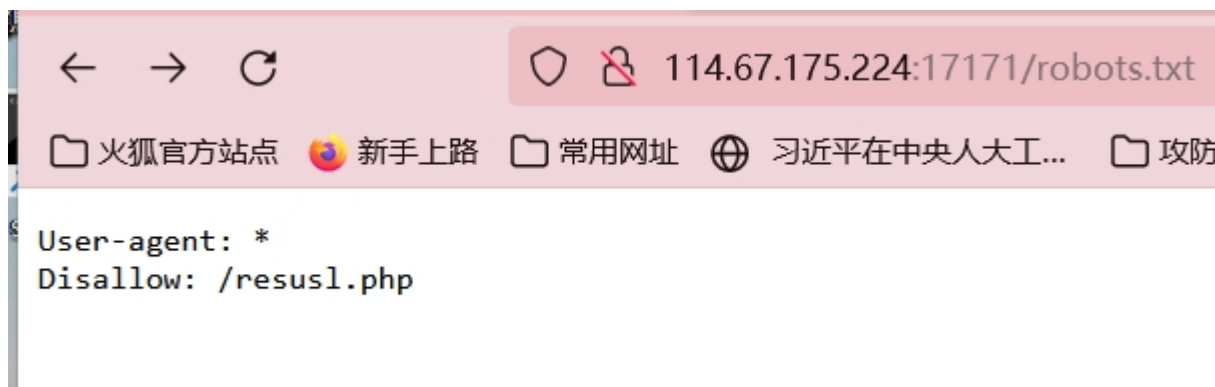
访问页面啥也没有



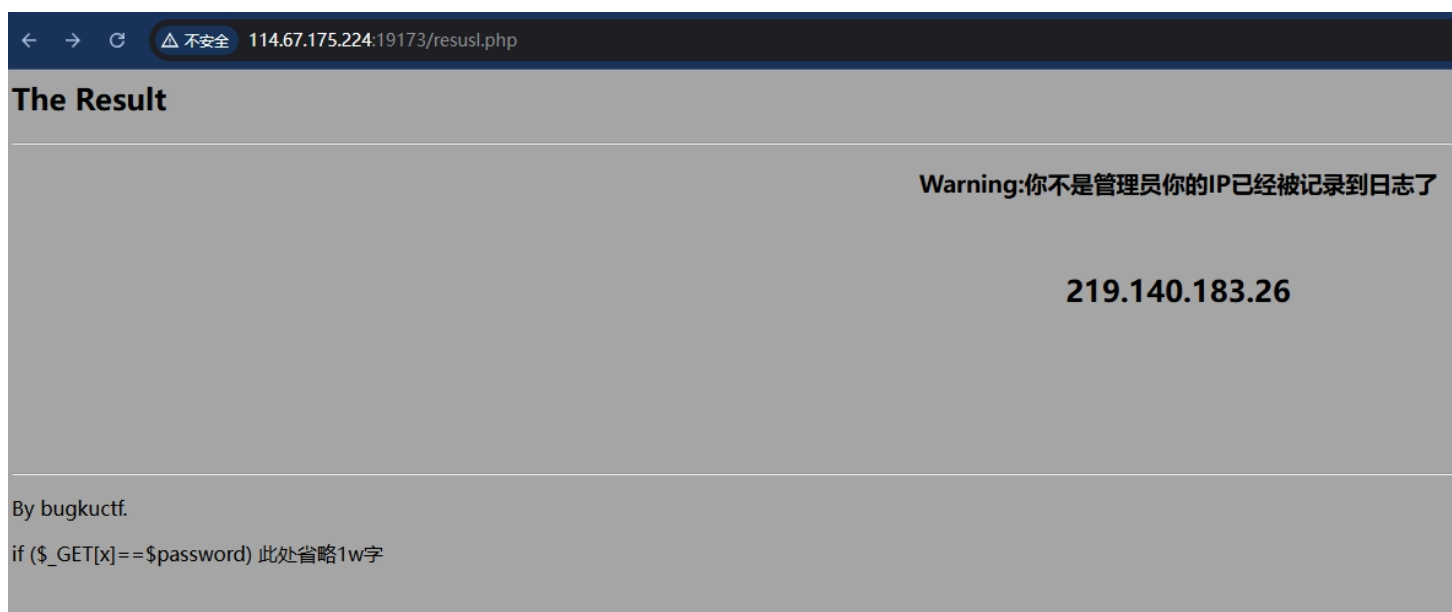
扫描后台只有一个 robots.txt 文件



访问得到一个禁止访问的 resusl.php



URL 跟上访问给出了一段源代码



结合题目名称传参 x=admin 拿到 flag

← → ↻

⚠ 不安全 114.67.175.224:19173/resusl.php?x=admin

The Result

厉害了!

flag{63748f81956bde06b6d20d3ff894d20c}

0

By bugkuctf.

if (\$\_GET[x]==\$password) 此处省略1w字

SSL 证书泄露

hackipy Create Challenge.txt

Code

Blame

6 lines (3 loc) · 156 Bytes

Code 55% faster with GitHub Copilot

1

When did testenv.sarimraza.com went from http to https (First Time)? Find the date :p

2

3

Note: Flag Format: KIET\_CTF{YYYY-MM-DD}

4

5

Flag: KIET\_CTF{2021-08-25}

题目翻译就问这个网站什么时候从 HTTP 转到了 HTTPS

如果自己搭建过网站同学都知道，申请 HTTPS 是需要 SSL 证书的

这个证书可以去在线网站查询的，去这个网站查询域名可以看到证书信息

crt.sh Identity Search

Criteria

Type: Identity Match: ILIKE Search: 'testenv.sarimraza.com'

| Certificates | crt.sh ID                   | Logged At  | Not Before | Not After  | Common Name               | Matching Identities       | Issuer Name                                                                         |
|--------------|-----------------------------|------------|------------|------------|---------------------------|---------------------------|-------------------------------------------------------------------------------------|
|              | <a href="#">15588836914</a> | 2024-12-02 | 2024-12-02 | 2025-03-02 | testenv.sarimraza.com     | testenv.sarimraza.com     | C=US, O=Let's Encrypt, CN=R10                                                       |
|              | <a href="#">5948357379</a>  | 2022-01-10 | 2022-01-10 | 2022-04-10 | www.testenv.sarimraza.com | www.testenv.sarimraza.com | C=US, O=Let's Encrypt, CN=R3                                                        |
|              | <a href="#">5948357902</a>  | 2022-01-10 | 2022-01-10 | 2022-04-10 | www.testenv.sarimraza.com | www.testenv.sarimraza.com | C=US, O=Let's Encrypt, CN=R3                                                        |
|              | <a href="#">5572271833</a>  | 2021-11-09 | 2021-11-09 | 2022-02-07 | testenv.sarimraza.com     | testenv.sarimraza.com     | C=US, ST=TX, L=Houston, O="cPanel, Inc.", CN="cPanel, Inc. Certification Authority" |
|              | <a href="#">5572271199</a>  | 2021-11-09 | 2021-11-09 | 2022-02-07 | testenv.sarimraza.com     | testenv.sarimraza.com     | C=US, ST=TX, L=Houston, O="cPanel, Inc.", CN="cPanel, Inc. Certification Authority" |
|              | <a href="#">5105965275</a>  | 2021-08-25 | 2021-08-25 | 2021-11-23 | testenv.sarimraza.com     | testenv.sarimraza.com     | C=US, ST=TX, L=Houston, O="cPanel, Inc.", CN="cPanel, Inc. Certification Authority" |
|              | <a href="#">5105965111</a>  | 2021-08-25 | 2021-08-25 | 2021-11-23 | testenv.sarimraza.com     | testenv.sarimraza.com     | C=US, ST=TX, L=Houston, O="cPanel, Inc.", CN="cPanel, Inc. Certification Authority" |

© Sectigo Limited 2015-2024. All rights reserved.

网站历史信息泄露

黑客 创建挑战.txt

代码 责备 5 行 (3 位置) · 211 字节 使用 GitHub Copilot 编码速度提高 55%

1

告诉我 2008 年 12 月 19 日在 pafkiet.edu.pk 网站上加载 Flash SWF 文件失败并且错误显示在主页上的软件名称。

2

3

注意: 标志格式为 KIET\_CTF{Name}

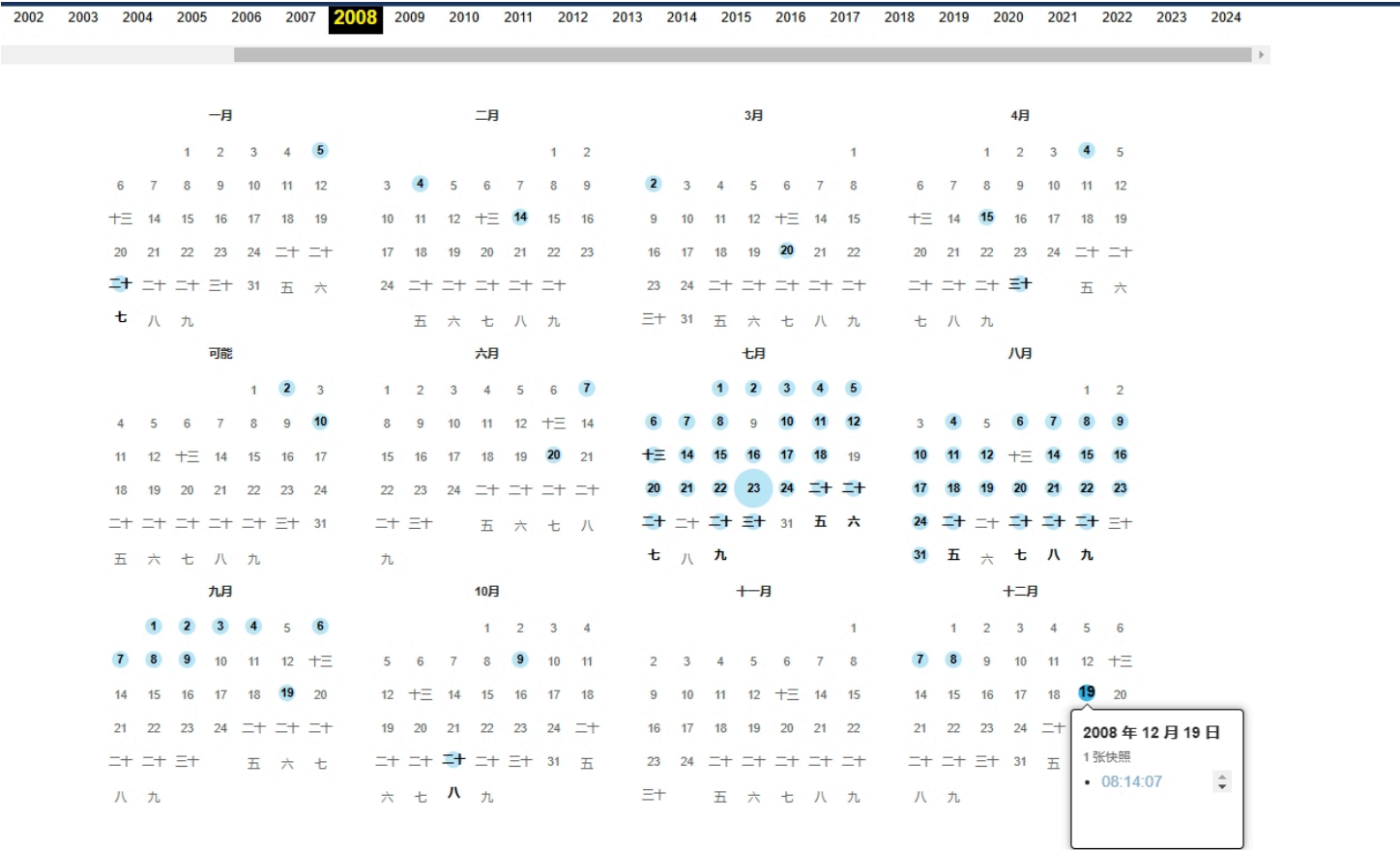
4

5

标志: KIET\_CTF{Ruffle}

考察的信息搜集能力，web.archive.org 免费提供全球网站历史信息查询服务，最早可追溯到 1996 年

具体题目提供的时间查找快照



该图映射了pafkiet.edu.pk被 Wayback Machine 抓取的次数，而不是该网站实际更新的次数。更多信息请参阅[常见问题解答](#)。

往下翻拿到 flag

## JavaScript 接口泄露



打开网页不让 F12 以及右键



Ctrl + U 发现有个 PHP 文件



```

14     cursor: pointer;
15 }
16
17 #custom-background {
18     position: fixed;
19     top: 0;
20     left: 0;
21     width: 100%;
22     height: 100%;
23     z-index: -1;
24 }
25
26
27 body {
28     user-select: none;
29     -webkit-user-select: none;
30     -moz-user-select: none;
31     -ms-user-select: none;
32 }
33
34 body:contextmenu {
35     display: none;
36 }
37 </style>
38 </head>
39 <body oncontextmenu="return false">
40     <div id="text">click to me,Baby</div>
41
42     <script>
43
44         document.addEventListener('keydown', function(event) {
45             if (event.key === 'F12') {
46                 event.preventDefault();
47             }
48         });
49
50         var text = document.getElementById('text');
51         var customBackground = document.createElement('img');
52
53         customBackground.setAttribute('id', 'custom-background');
54         customBackground.src = './image/2.png';
55         document.body.appendChild(customBackground);
56
57         text.addEventListener('click', function() {
58             window.location.href = 'c3s4f.php';
59         });
60
61         text.addEventListener('mouseover', function() {
62             moveText();
63         });
64
65         function moveText() {
66             var windowWidth = window.innerWidth;
67             var windowHeight = window.innerHeight;
68
69             var newPositionX = Math.random() * (windowWidth - text.offsetWidth);
70             var newPositionY = Math.random() * (windowHeight - text.offsetHeight);
71
72             text.style.left = newPositionX + 'px';
73             text.style.top = newPositionY + 'px';
74         }
75     </script>
76 </body>
77 </html>

```

访问页面后再次查看源码给出了提示

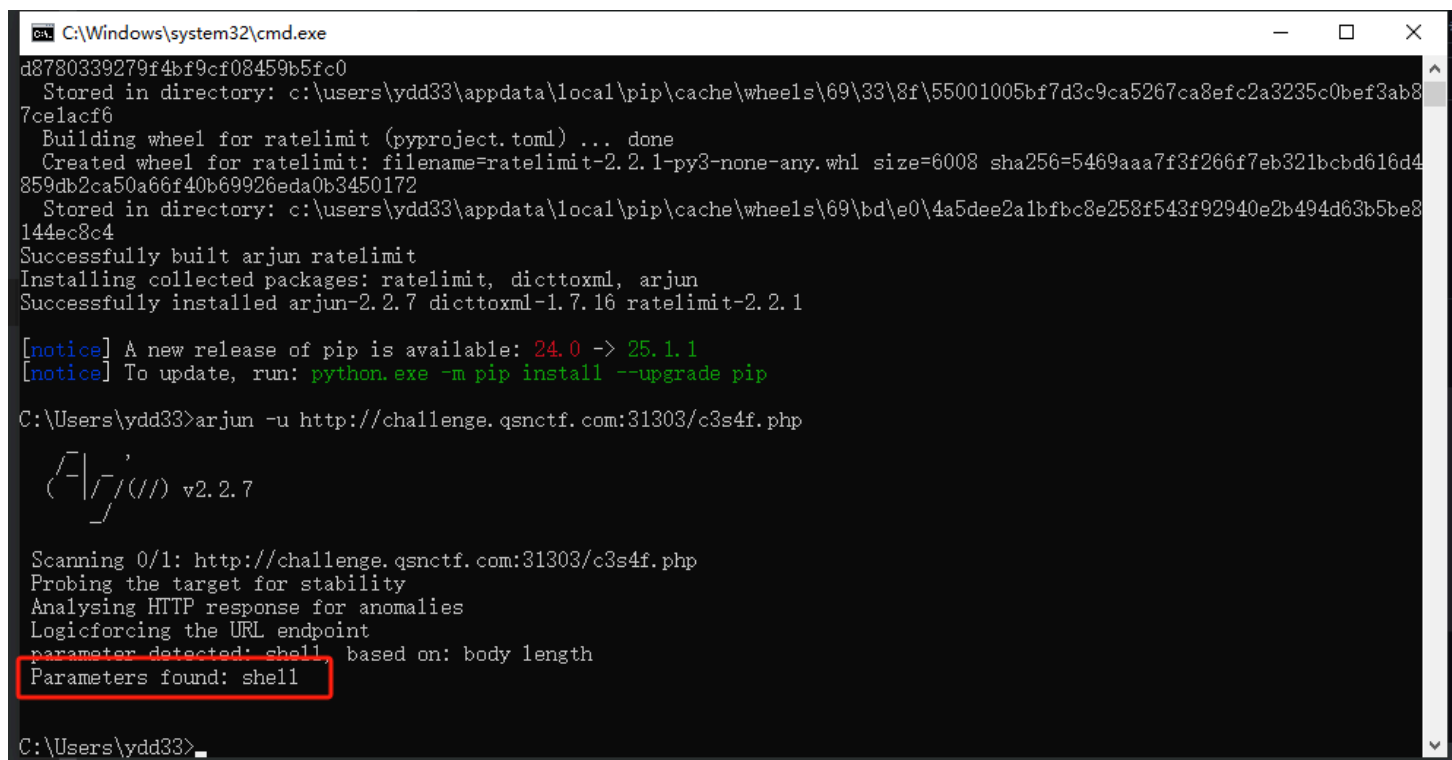
```
pip install arjun
```



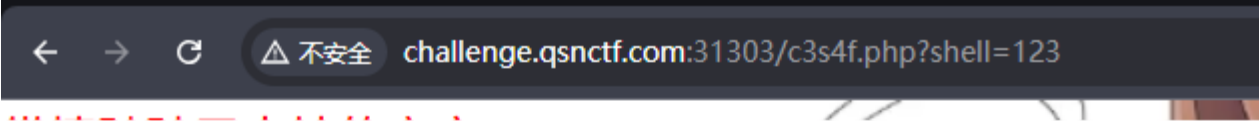
## 执行命令

```
arjun -u http://challenge.qsnctf.com:31303/c3s4f.php
```

可以发现有个 `shell` 参数



传入参数给出了新提示



扫描目录发现有个 `secret.php`

线程:  (条 CPU核心 \* 5最佳)

超时:  (秒 超时的页面被丢弃)

☐ DIR: 87595

☐ ASP: 272626

☐ MDB: 17528

☐ ASPX: 137621

☒ PHP: 346086

☐ JSP: 60173

☒ 探测200

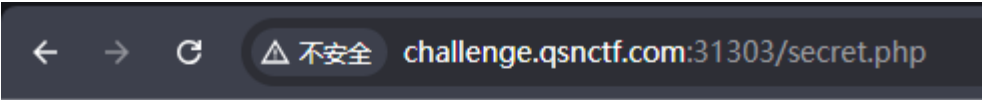
☒ 探测403

☒ 探测3XX

扫描信息: http://challenge.qsnctf.com:31402/include/template/gbk/ppf/exam/manage/b 扫描线程: 5 扫描速度: 10

| ID | 地址                                           | HTTP响应 |
|----|----------------------------------------------|--------|
| 1  | http://challenge.qsnctf.com:31402/secret.php | 200    |
| 2  | http://challenge.qsnctf.com:31402/index.html | 200    |
| 3  | http://challenge.qsnctf.com:31402/image/     | 403    |
| 4  | http://challenge.qsnctf.com:31402/flag.php   | 200    |

只允许本地访问



You may have broken the rules.

Only local access is allowed

结合提示以为是要伪造 XFF 或者 Client-IP，试过了都不行

利用 `shell` 参数构造 SSRF

```
?shell=http://127.0.0.1/secret.php
```

无果

纵情驰骋于本地的宇宙

方能寻觅那个看不到的存在

binggo!你FUZZ出来了捏!!

但是我只把秘密给127.0.0.1哦(๑^•๑^๑)error!!!!!!

使用域名跳转绕过

纵情驰骋于本地的宇宙

方能寻觅那个看不到的存在

binggo!你FUZZ出来了捏!!

但是我只把秘密给127.0.0.1哦(๑^•๑^๑)You may have broken the rules.

Only local access is allowed

Give you my key:MSIBLG

Hurry up and go to the next level:cha11eng3.php1bool(true)

访问拿到源码

```
<?php
show_source(__FILE__);
include('k4y.php');
include_once('flag.php');

// Challenge 1
if (isset($_GET['DrKn'])) {
    $text = $_GET['DrKn'];
    if(@file_get_contents($text) == $key) {
        echo "有点东西呢."</br>".$key1."</br>";
    } else {
        die("貌似状态不在线啊(´_`)</br>");
    }
}

// Challenge 2
if (isset($_GET[$key1])) {
    $damei = $_GET[$key1];
    if (hash("md4", $damei) == $damei) {
        echo "又近了一步呢，宝~."</br>".$key2."</br>".$key3;
    } else {
        die("达咩哟~");
    }
}

// Challenge 3
if (isset($_POST[$key2]) && isset($_POST[$key3])) {
    $user = $_POST[$key2];
    $pass = $_POST[$key3];

    if (strlen($user) > 4 || strlen($pass) > 5) {
        die("还得练");
    }
    if ($user !== $pass && md5($user) === md5($pass)) {
        echo "还不错哦".$flag;
    }
    else {
        die("nonono") ;
    }
}

?>
```

```
<?php
show_source(__FILE__);
include('k4y.php');
include_once('flag.php');

// Challenge 1
if (isset($_GET['DrKn'])) {
    $text = $_GET['DrKn'];
    if(@file_get_contents($text) == $key) {
        echo "有点东西呢."</br>".$key1."</br>";
    } else {
        die("貌似状态不在线啊(´_`)</br>");
    }
}

// Challenge 2
```

```
if (isset($_GET[$key1])) {
    $damei = $_GET[$key1];
    if (hash("md4", $damei) == $damei) {
        echo "又近了一步呢, 宝~". "</br>".$key2."</br>".$key3;
    } else {
        die("达咩哟~");
    }
}

// Challenge 3
if (isset($_POST[$key2]) && isset($_POST[$key3])) {
    $user = $_POST[$key2];
    $pass = $_POST[$key3];

    if (strlen($user) > 4 || strlen($pass) > 5) {
        die("还得练");
    }
    if ($user !== $pass && md5($user) === md5($pass)) {
        echo "还不错哦"."$flag";
    }
    else {
        die("nonono") ;
    }
}

?>
```

第一关就是传入给出的 Key，但是需要用到 `data` 伪协议

```
// Challenge 2
if (isset($_GET[$key1])) {
    $damei = $_GET[$key1];
    if (hash("md4", $damei) == $damei) {
        echo "又近了一步呢, 宝~". "<br>".$key2."<br>".$key3;
    } else {
        die("达咩哟~");
    }
}

// Challenge 3
if (isset($_POST[$key2]) && isset($_POST[$key3])) {
    $user = $_POST[$key2];
    $pass = $_POST[$key3];

    if (strlen($user) > 4 || strlen($pass) > 5) {
        die("还得练");
    }
    if ($user != $pass && md5($user) == md5($pass)) {
        echo "还不错哦".$flag;
    }
    else {
        die("nonono");
    }
}
```



`&M_ore.8=0e00123333333333333333334557778889`





```
morant@DESKTOP-JRG4U86: ~$ wget http://challenge-a6ac5f421d6d5bd8.sandbox.ctfhub.com:10800/.index.php.swp
--2025-07-17 15:39:14-- http://challenge-a6ac5f421d6d5bd8.sandbox.ctfhub.com:10800/.index.php.swp
Resolving challenge-a6ac5f421d6d5bd8.sandbox.ctfhub.com (challenge-a6ac5f421d6d5bd8.sandbox.ctfhub.com)... 47.98.117.93
Connecting to challenge-a6ac5f421d6d5bd8.sandbox.ctfhub.com (challenge-a6ac5f421d6d5bd8.sandbox.ctfhub.com)|47.98.117.93|:10800... connected.
HTTP request sent, awaiting response... 200 OK
Length: 12288 (12K)
Saving to: '.index.php.swp.1'

.index.php.swp.1      100%[=====] 12.00K  --.-KB/s   in 0.05s

2025-07-17 15:39:14 (220 KB/s) - '.index.php.swp.1' saved [12288/12288]

(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$ vim .index.php.swp
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$ cat .index.php.swp
3210#! Utpadtctc*****zyrLB?f</html></body>    <p>flag 在 index.php 源码中</p>    <br/>    <h1>备份文件下载 - vim</h1>
<body></head>    <title>CTFHub BackUp Vim</title>    <meta charset="UTF-8" /><head><html?>// ctfhub{2f8b9883c4342e794a3fc9b9}<?php
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$ rm .index.php.swp
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$
(base) morant@DESKTOP-JRG4U86:/mnt/c/Users/ydd33$ |
```

[上一页](#)

[下一页](#)

[←](#) Web 入门题单

PHP 基础

[→](#)